

An OWL-Based Ontology for NIS2 Article 21 Compliance

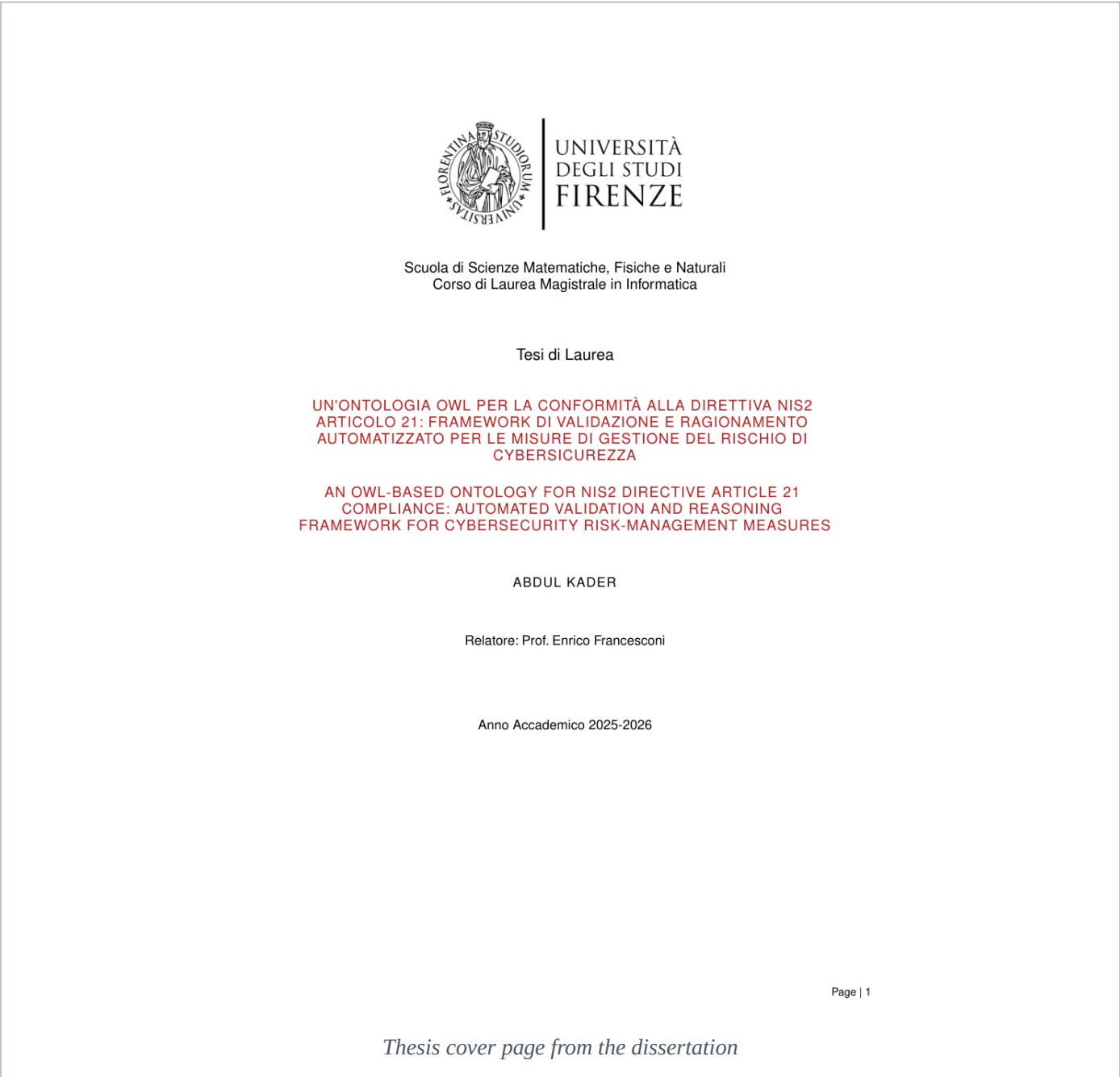
A formal, machine-readable framework for representing and evaluating cybersecurity risk-management obligations.

- Candidate: Abdul Kader
- Supervisor: Prof. Enrico Francesconi
- Focus: research problem, methodology, implementation, findings, and limitations

OWL 2 DL

SHACL

SPARQL



Research problem and objective

Motivation for a formal compliance model

- NIS2 Article 21 requires entities to adopt technical, operational, and organizational cybersecurity risk-management measures.
- Compliance assessment is frequently performed through manual document review and fragmented evidence collection.
- Manual assessment can reduce consistency, reproducibility, and transparency in the interpretation of requirements.
- The thesis objective is to represent Article 21 compliance in a machine-readable and explainable form.

What the thesis contributes

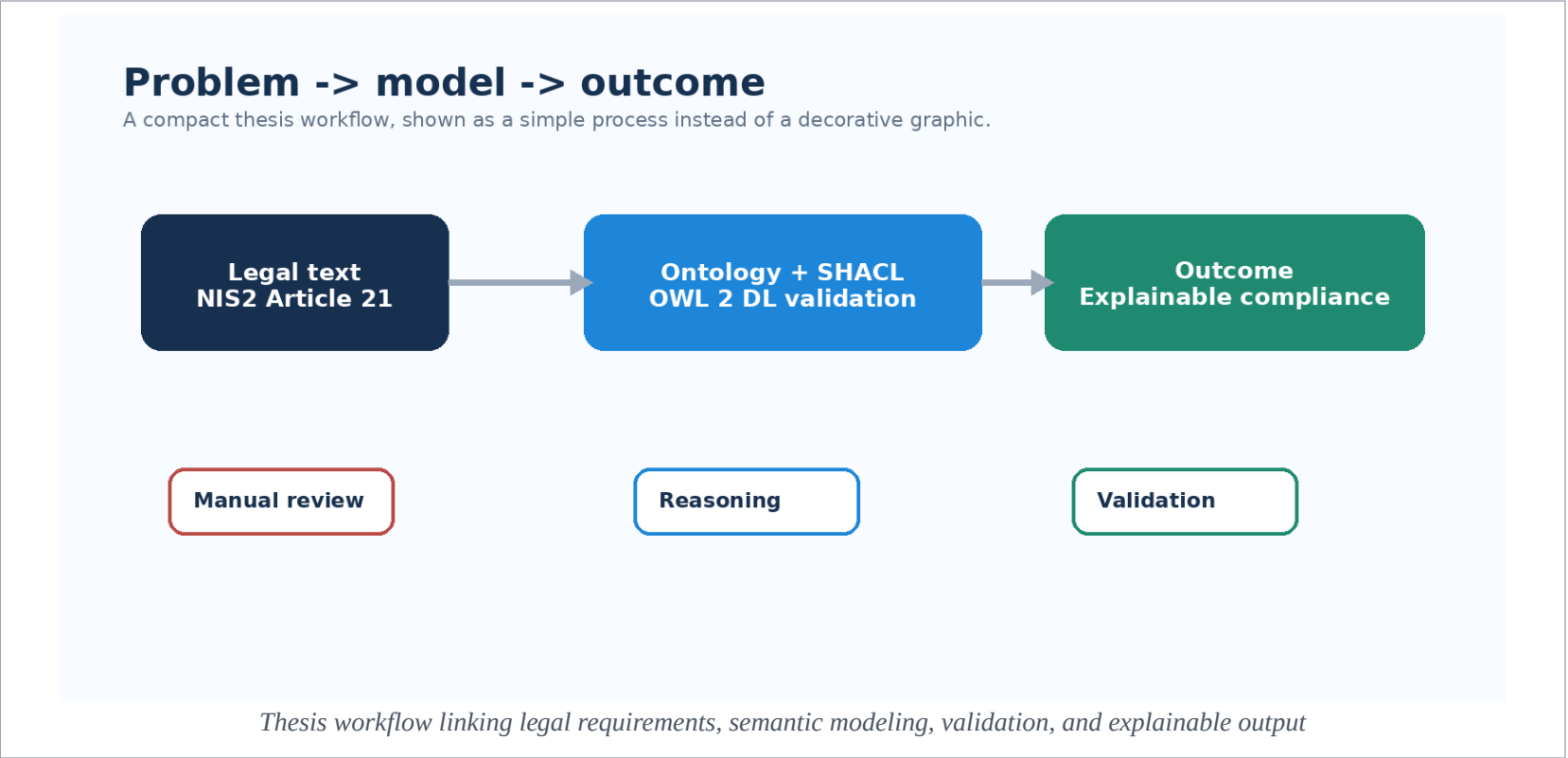
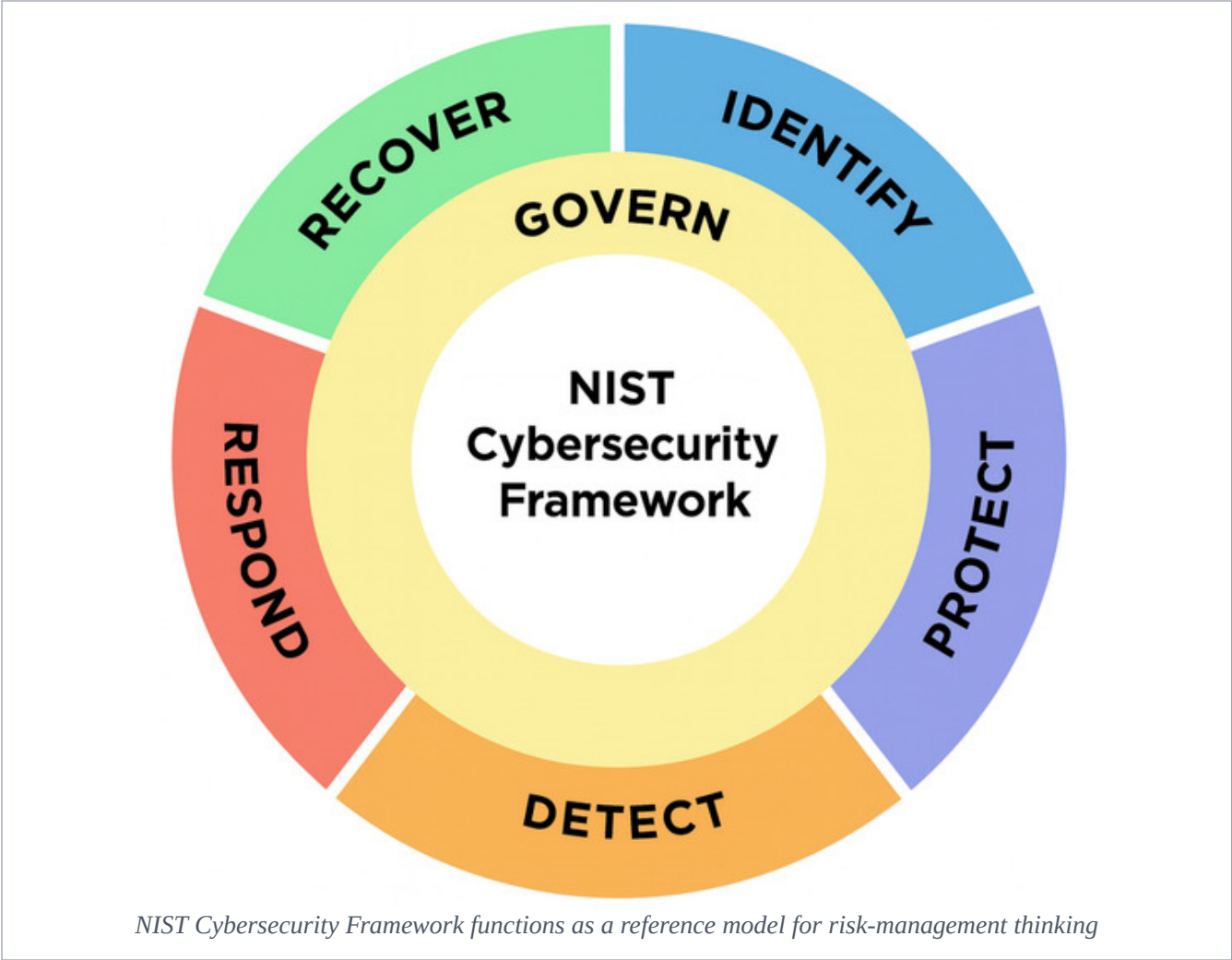
- An OWL 2 DL ontology covering the Article 21(2) measure categories.
- A compliance classification pattern inferred from implemented measures.
- SHACL constraints for detecting absent or incomplete compliance evidence.
- A compact web application for ontology inspection, querying, and visualization.

Research objective

Transform legal obligations into a structured compliance artifact that can be checked, queried, and explained.

Regulatory and standards context

Positioning NIS2 Article 21 within cybersecurity risk management

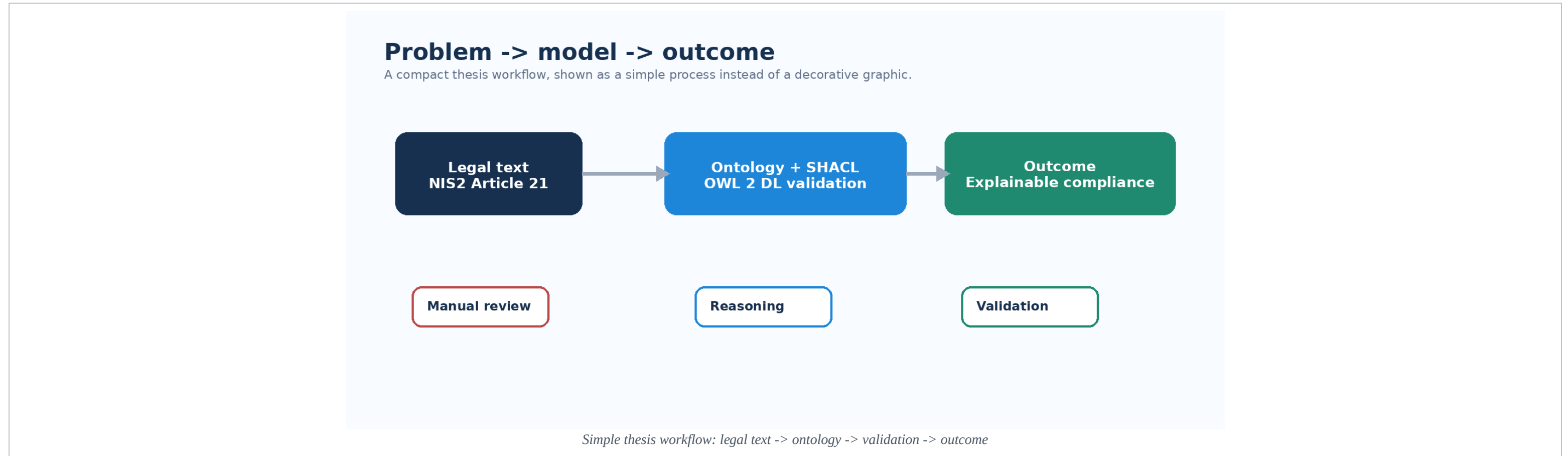


Analytical relevance

The presentation connects a regulatory obligation, NIS2 Article 21, with established cybersecurity governance concepts. This makes the ontology easier to interpret as both a legal-compliance artifact and a risk-management model.

Methodological approach

From legal text to computable compliance



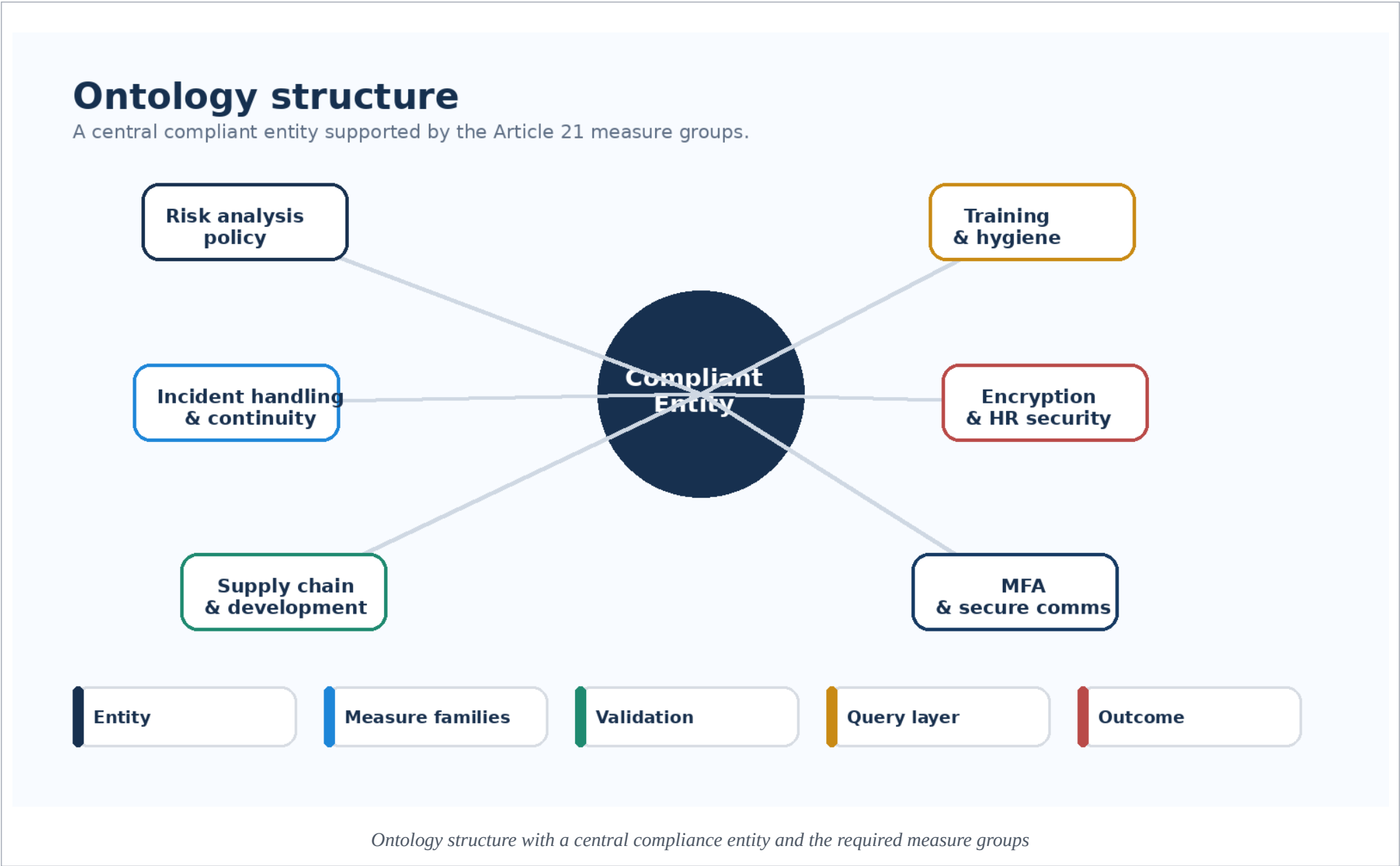
- A design-science methodology is used: construct the artifact and evaluate its behavior against representative cases.
- OWL 2 DL provides the semantic structure required for classification and reasoning.
- SHACL validates whether required compliance evidence is present and structurally complete.
- SPARQL enables inspection, querying, and lightweight reporting over the knowledge graph.

Modeling decision

The thesis models the ten legal points as twelve operational classes, separating point (g) and point (j) where the legal wording combines distinct compliance concerns.

Ontology model

The structure that makes compliance computable



Key classes

- Entity and RiskManagementMeasure
- Technical, Operational, Organizational measures
- CybersecurityRisk and SecurityIncident
- SecurityStandard and NetworkInformationSystem

Analytical significance

- Preserves the link between legal provisions and technical model elements.
- Allows the reasoner to infer compliance-relevant classifications.
- Supports explanation of outcomes rather than only a binary result.

Dissertation figures: ontology implementation

Selected implementation figures from Chapter 6

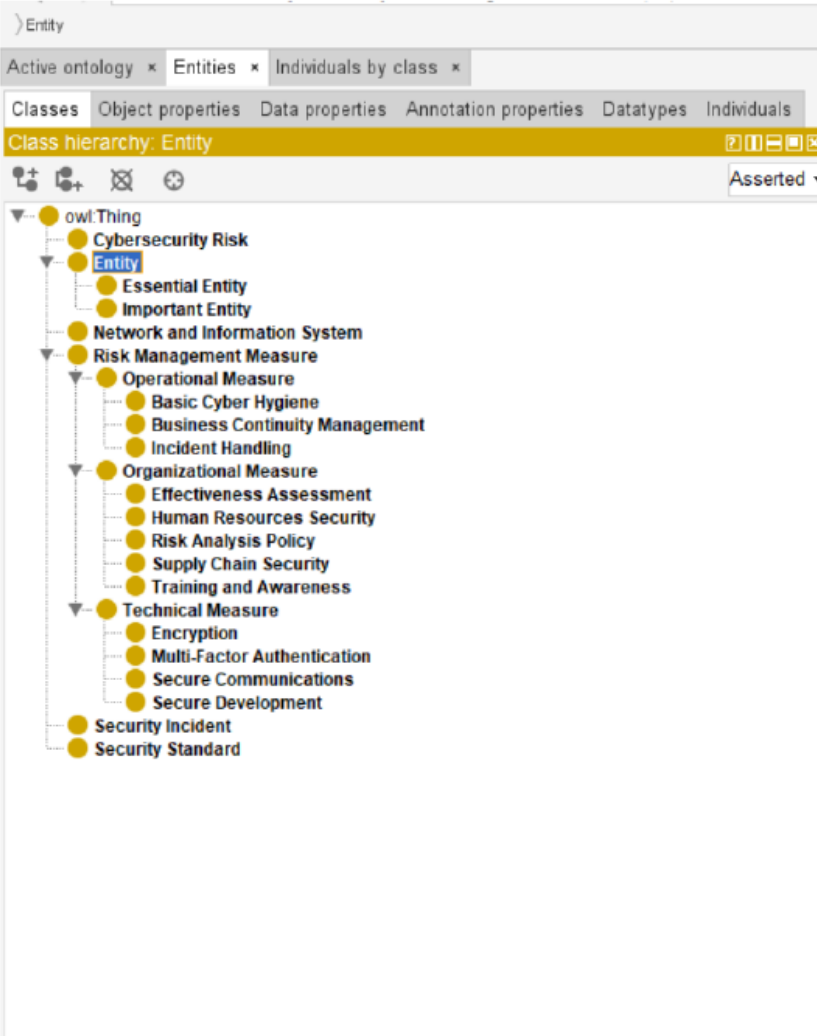


Figure 6.1: Protégé class hierarchy for the NIS2 Article 21 ontology

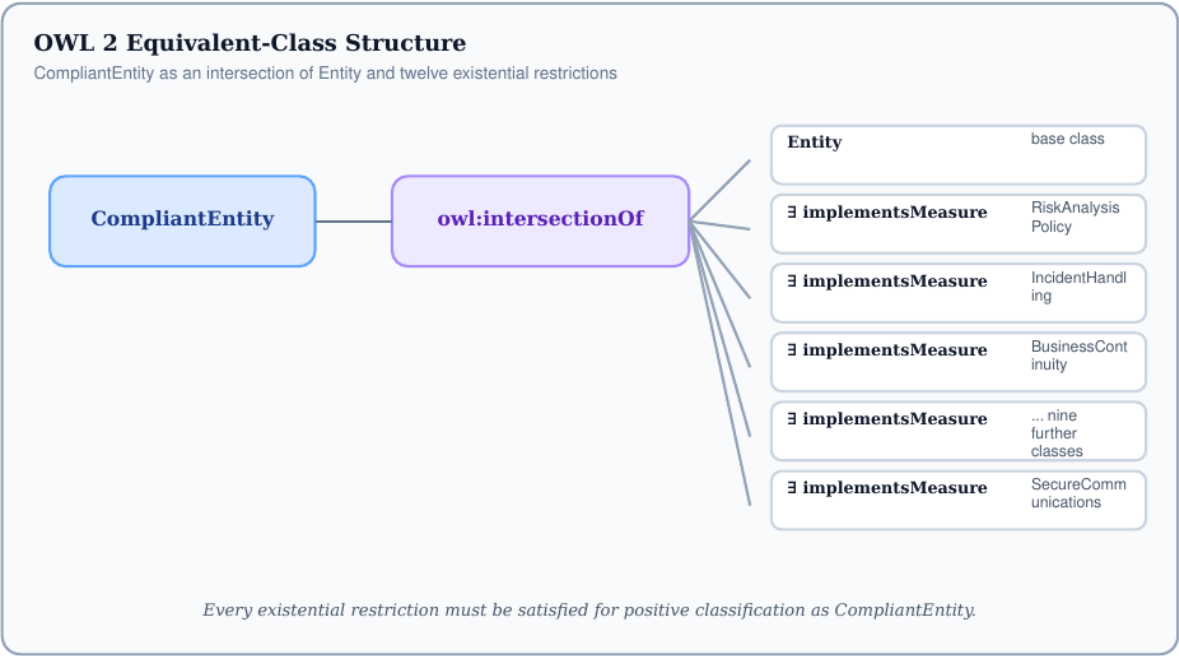


Figure 6.4: OWL equivalent-class structure for CompliantEntity

Interpretation

These figures show that the thesis artifact is not only conceptual. The ontology was implemented in OWL, inspected in Protégé, and structured around a compliance class whose definition requires coverage of the operational Article 21 measure categories.

Validation and results

Prototype-level evaluation findings

Art. 21(2)	Legal obligation (abbreviated)	State of affair	Verdict
(a)	Risk analysis and information system security policies	Med Center Risk Analysis Policy implemented	COMPLIANT
(b)	Incident handling procedures and capabilities	Med Center Incident Handling implemented	COMPLIANT
(c)	Business continuity, backup management, disaster recovery	No measure asserted	VIOLATION
(d)	Supply chain security and supplier relationships	No measure asserted	VIOLATION
(e)	Security in NIS acquisition, development and maintenance	No measure asserted	VIOLATION
(f)	Policies to assess effectiveness of risk measures	No measure asserted	VIOLATION
(g)	Basic cyber hygiene practices and training	Basic Cyber Hygiene + Training Awareness	COMPLIANT
(h)	Policies regarding cryptography and encryption	Med Center Encryption implemented	COMPLIANT
(i)	Human resources security, access control, asset mgmt	No measure asserted	VIOLATION
(j)	MFA / continuous authentication + secured communications	MFA only; no Secure Communications	PARTIAL

Article 21(2)(j) warrants special attention: the ontology decomposes this norm into two operational classes — MultiFactorAuthentication and SecureCommunications — because the directive text covers both authentication solutions and secured voice/video/text communications. MedCenterHospital satisfies the authentication component but not the *Worked example from the thesis showing the partial healthcare case and verdicts*

Observed outcome

12 / 12

Full coverage leads to the inferred `CompliantEntity` class.

6 / 12

Partial coverage stays non-compliant and makes the gaps visible.

Interpretation

- The result represents modeled coverage, not formal legal certification.
- Each missing requirement category is identified explicitly.
- Legal judgment remains separate from the computational model.

Comparison and limitations

Scope of contribution and stated boundaries

9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

Approach	Formal Semantics	Auto Reasoning	SPARQL	SHACL	Open Source
This thesis (OWL+SHACL)	Yes (OWL 2 DL)	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No
ENISA checklist	No	No	No	No	Yes
Hassan 2025 (Legal Ontology)	Yes (OWL 2 DL)	Yes	Yes	No	Yes
Manual audit	No	No	No	No	N/ A

The comparison shows that the prototype combines several capabilities in one demonstrator. It should not be read as evidence that it is more complete than every commercial or academic alternative, because the compared categories differ in scope, evidence management, workflow, assurance, and production maturity.

9.6 Competency-Question Evaluation

All five competency questions can be expressed using the ontology vocabulary and executed through the query interface. Returned bindings correspond to manually inspected triples and expected inference paths.

This confirms functional adequacy for the declared information needs and demonstrates that the conceptual model supports risk, standard, incident, system, and implementation analysis.

The selected questions use a bounded query subset and do not establish complete SPARQL 1.1 conformance.

Comparison from the thesis: OWL + SHACL + SPARQL in one demonstrator

Strength

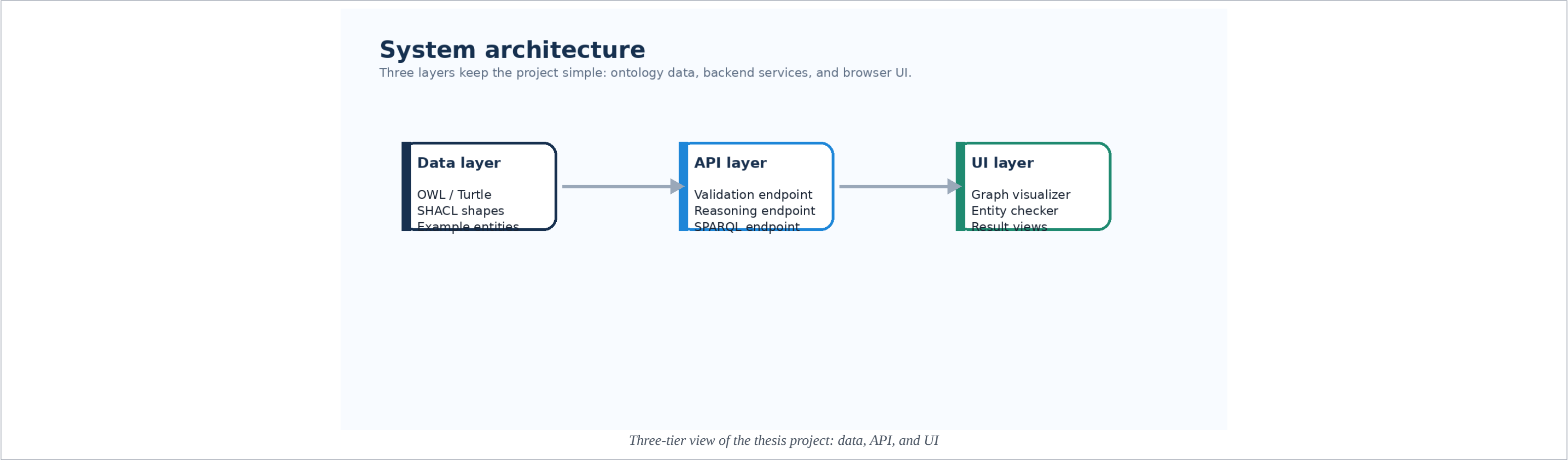
- Formal semantics through OWL 2 DL
- Constraint validation through SHACL
- Transparent inspection through SPARQL queries

Limitations

- Reasoning is demonstrated within a bounded prototype setting.
- The artifact is not a complete production compliance-management system.
- Evidence lifecycle management, provenance, and governance workflows remain future work.

System architecture

Implementation structure of the prototype



- The ontology is stored as RDF/OWL and loaded by the backend service.
- The API exposes validation, reasoning, and ontology-data endpoints.
- The browser interface supports graph exploration and preliminary compliance checks.

Research questions

What the thesis set out to answer

Research questions

The presentation should answer these three things early and clearly.

Can Article 21(2) be represented as a layered ontology?

Which OWL axiom pattern best captures compliance coverage?

How do SHACL and OWL complement one another?

Three research questions presented early, in a compact academic style

- RQ1: How can Article 21(2) be represented as a layered ontology?
- RQ2: Which OWL axiom pattern can express compliance coverage?
- RQ3: How can SHACL validation complement OWL reasoning?

Technology stack

Standards and implementation technologies

Technology stack

The thesis uses a small, standard stack rather than a heavy custom system.

OWL 2 DL

Protégé

SHACL

SPARQL

Express API

Why this matters

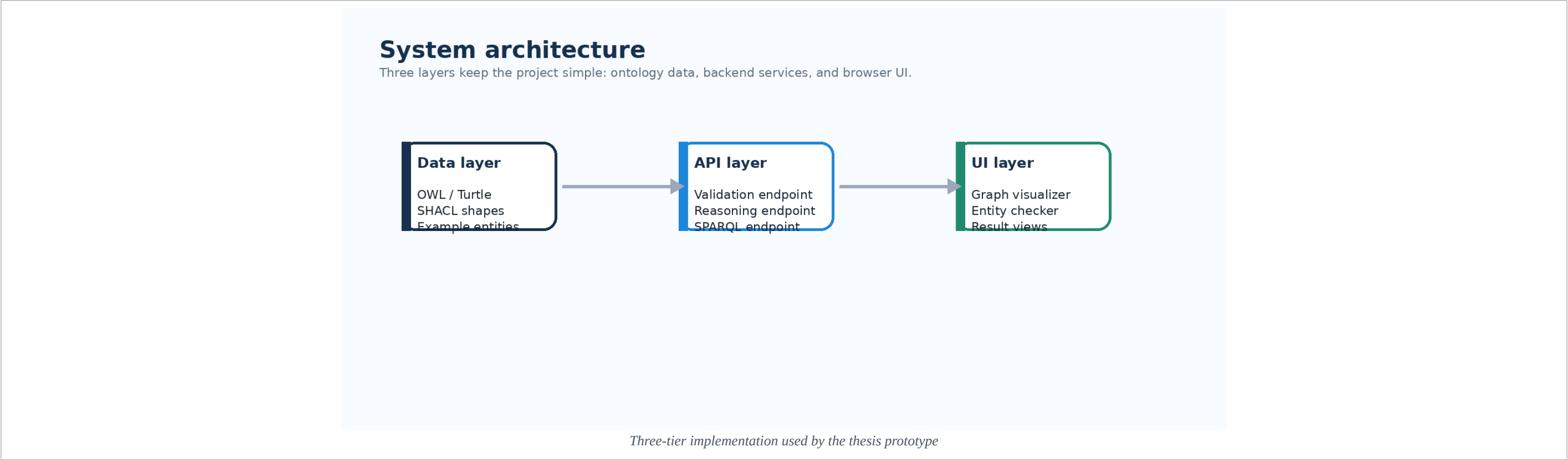
A small stack keeps the thesis reproducible, standard-based, and easier to explain in a defense.

OWL, Protégé, SHACL, SPARQL, and a small Express backend

- The stack is based on established and reproducible Semantic Web technologies.
- It keeps the thesis grounded in standards-based knowledge representation.
- It minimizes custom infrastructure so the research contribution remains clear.

Prototype architecture

Inspectable implementation layer



Implementation note

The prototype loads the ontology, exposes validation and reasoning endpoints, and presents results in a browser-based view suitable for inspection and demonstration.

Dissertation figures: ontology visualization

Graph excerpt from the implemented prototype

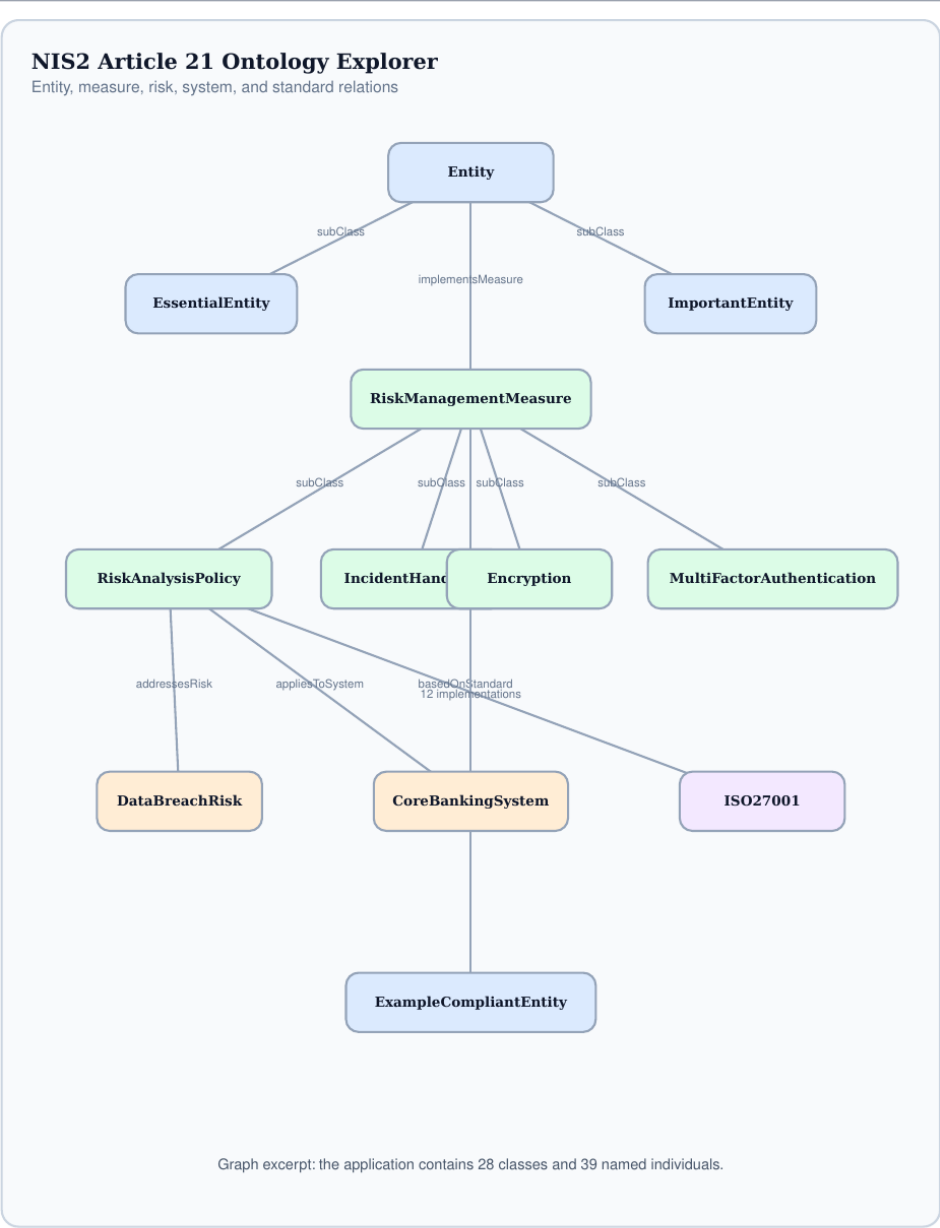


Figure 8.1: Ontology Explorer and Representative Relations
Figure 8.1: ontology explorer showing entity, measure, risk, system, and standard relations

Interpretive value

- Entities are connected to implemented measures.
- Measures are connected to systems, risks, and standards.
- The visualization makes the semantic model inspectable for a defense audience.

Connection to the research claim

This screenshot demonstrates the practical bridge between the ontology vocabulary and the web-based inspection layer. It supports the claim that the model can be queried and explained, not only stored as a static file.

Dissertation figures: prototype outputs

Reasoning and real-time compliance assessment

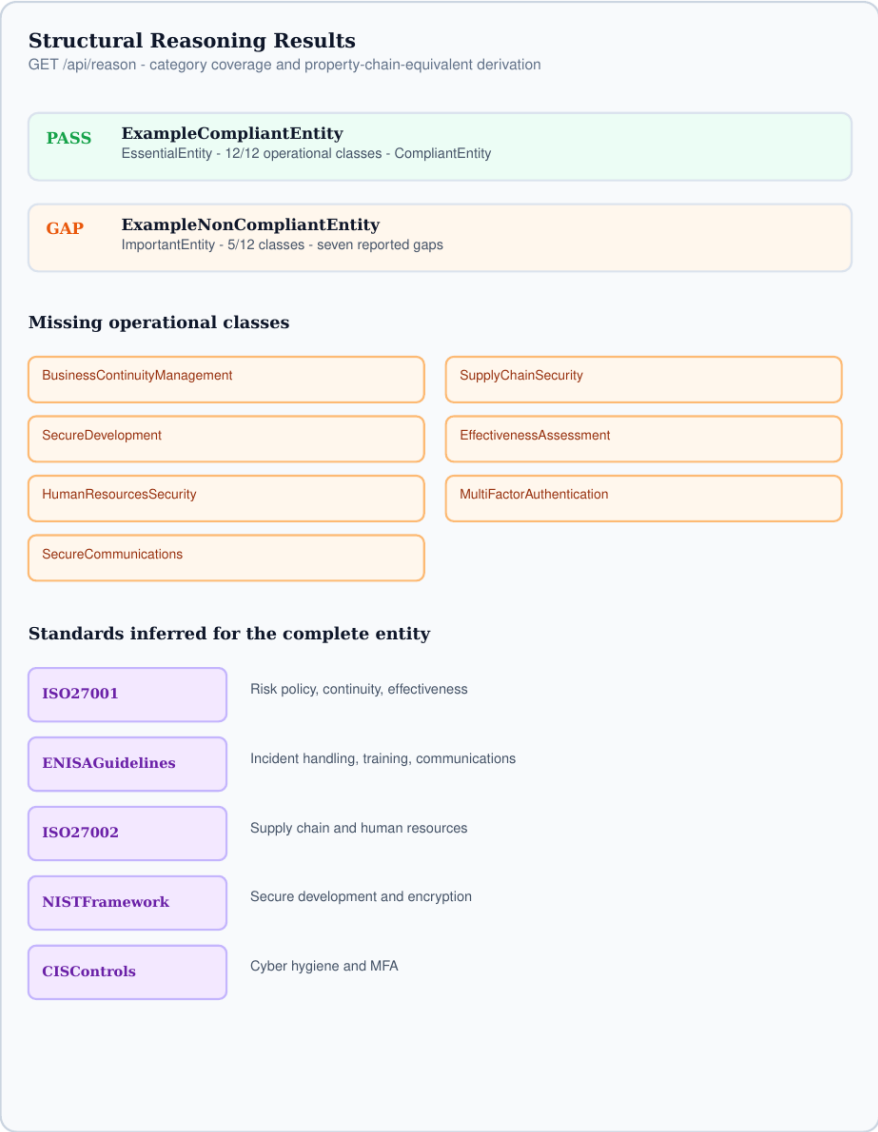
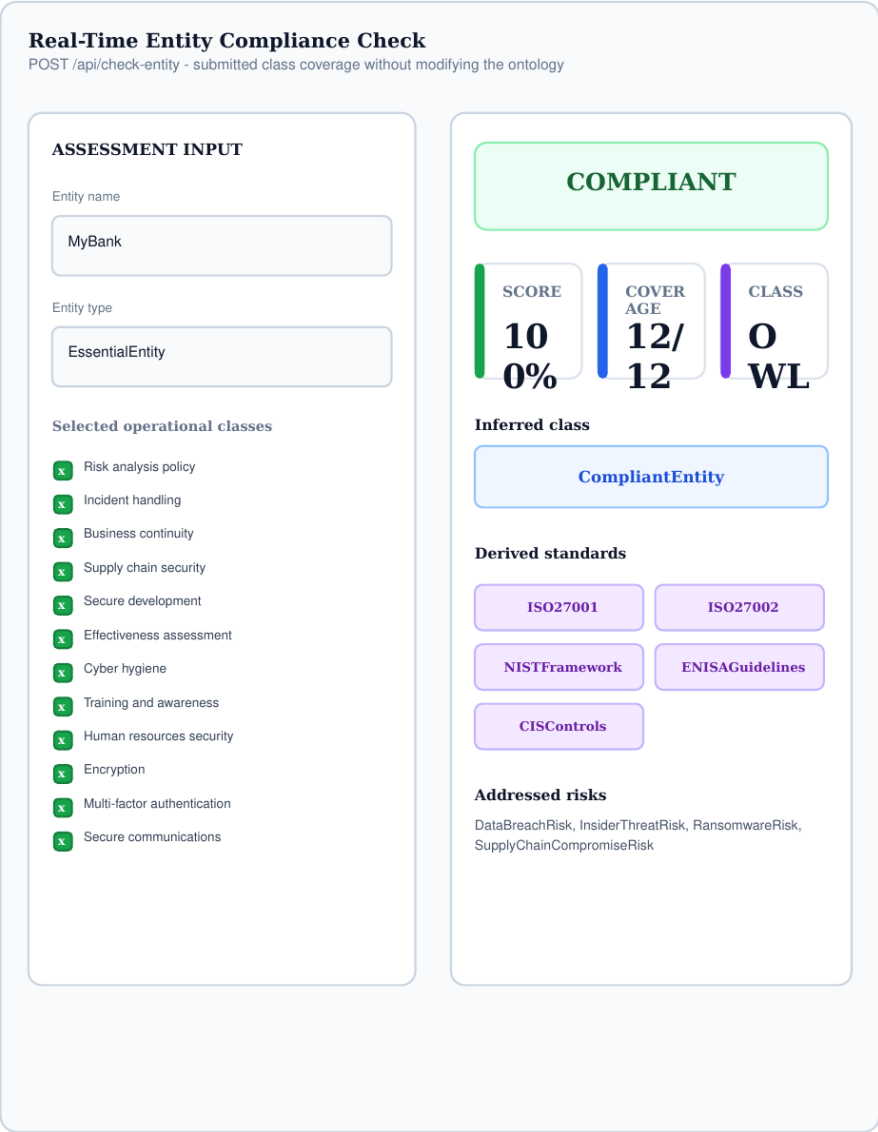


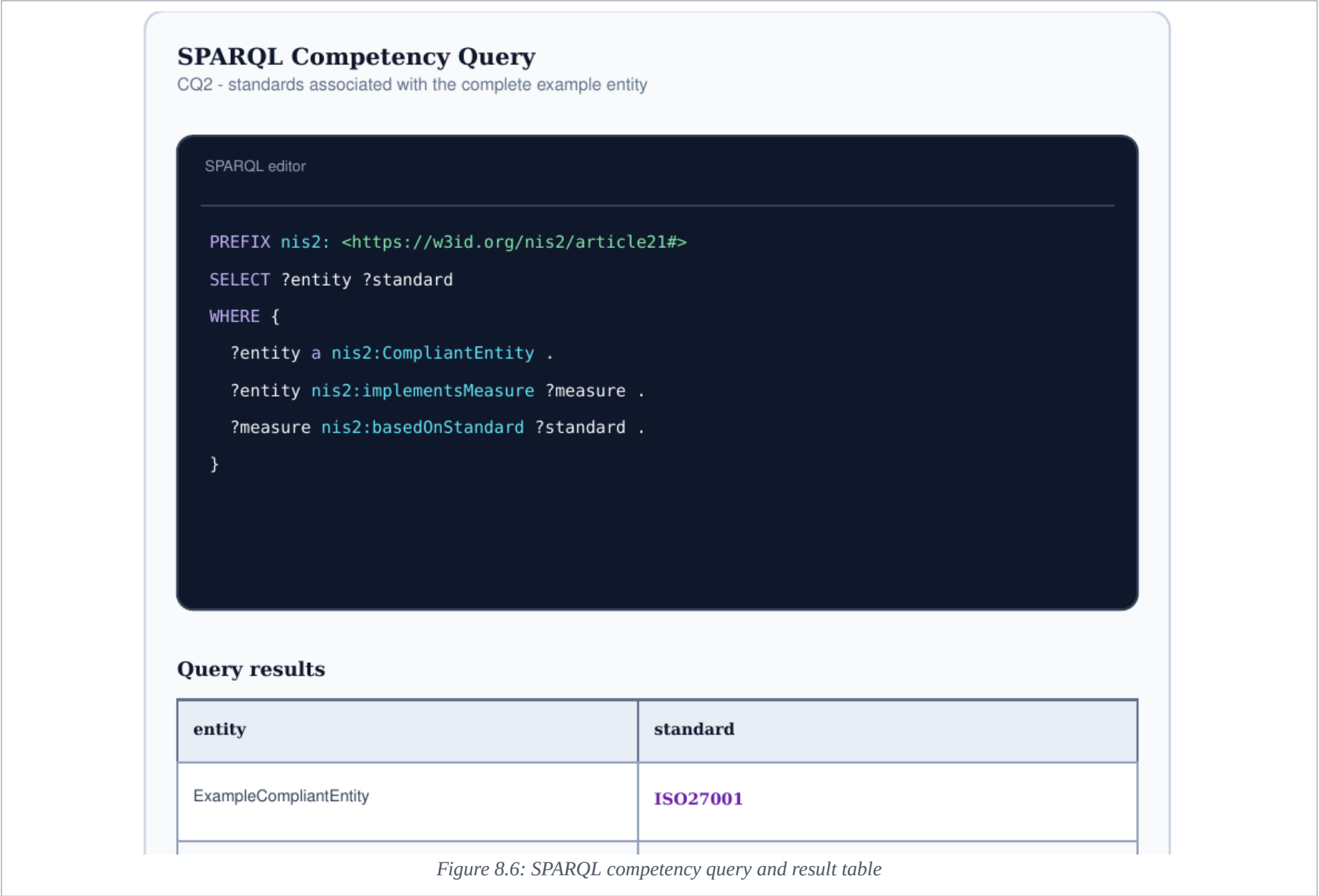
Figure 8.3: Entity Classification and Derived Standards

Figure 8.3: classification, missing classes, and derived standards



Dissertation figures: SPARQL query layer

Competency-question execution over the ontology graph



What this demonstrates

- The ontology can be inspected through query patterns.
- Standards associated with a compliant entity can be retrieved from graph relations.
- Competency questions provide a testable link between research requirements and system behavior.

This slide makes the query component visible, completing the educational sequence: ontology representation, validation, reasoning, and information retrieval.

Conclusion

Final synthesis of the research contribution

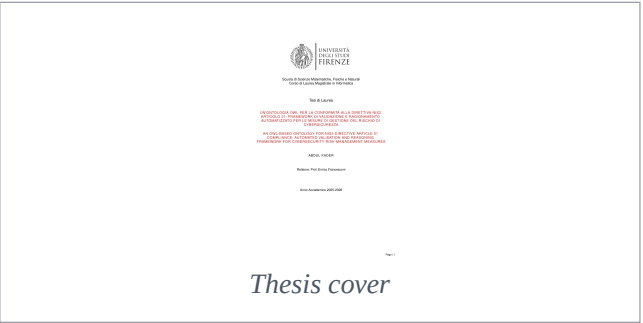
Takeaway

This thesis demonstrates that NIS2 Article 21 compliance can be represented as a formal ontology, validated with SHACL shapes, queried with SPARQL, and explained through a compact web application.

Core claims

- Manual verification can be made more consistent through formal representation.
- A traceable ontology provides a structured bridge between legal text and compliance evidence.
- The prototype demonstrates explicit gap detection and explainable compliance outcomes.

Thank you



Future work

Research extensions and validation requirements

Next steps

- Integrate the prototype with a standards-complete reasoner.
- Add evidence, provenance, and review metadata.
- Extend the model beyond Article 21 to other NIS2 duties.
- Evaluate the system with realistic organizational data and user feedback.

9.5 Comparison with Existing Approaches

The implemented framework is compared against three categories of existing approaches:

Approach	Formal Semantics	Auto Reasoning	SPARQL	SHACL	Open Source
This thesis (OWL+SHACL)	Yes (OWL 2 DL)	Yes	Yes	Yes	Yes
Commercial GRC tools	No	No	No	No	No
ENISA checklist	No	No	No	No	Yes
Hassan 2025 (Legal Ontology)	Yes (OWL 2 DL)	Yes	Yes	No	Yes
Manual audit	No	No	No	No	N/ A

The comparison shows that the prototype combines several capabilities in one demonstrator. It should not be read as evidence that it is more complete than every commercial or academic alternative, because the compared categories differ in scope, evidence management, workflow, assurance, and production maturity.

9.6 Competency-Question Evaluation

All five competency questions can be expressed using the ontology vocabulary and executed through the query interface. Returned bindings correspond to manually inspected triples and expected inference paths.

This confirms functional adequacy for the declared information needs and demonstrates that the conceptual model supports risk, standard, incident, system, and implementation analysis.

The selected questions use a bounded query subset and do not establish complete SPARQL 1.1 conformance.

A concise reminder that the thesis combines semantics, validation, and querying

Closing point

The thesis should be understood as a formal compliance framework and research demonstrator, not as a finished production system.